OPERATING MAP • 5 NOVEMBER 2026

Understanding the internal auditor's work

A standards-based operating map before product design

This consolidation focuses on what internal auditors need to understand, decide, do, document, review and communicate. It deliberately stops before feature recommendations.

Its primary source is the January 2024 **Global Internal Audit Standards** you supplied. Page references below refer to that 120-page PDF. The operating examples are illustrations, not claims that we observed those organisations or validated a universal workflow with practitioners. This is a detailed standards-based foundation, not yet a completed cross-industry field study.

The central insight is that an internal auditor is building a defensible professional judgment. Producing a workbook, completing a test and issuing a report are parts of that work, not its entire purpose. The judgment must connect the organisation's objectives, relevant risks, evaluation criteria, work performed, evidence obtained and conclusions reached. Management then decides and implements its response; internal audit follows up without taking over management's responsibility.

There are three connected cycles:

1. **Audit coverage across the organisation:** Where should independent assurance and advice be directed, given risks, expectations and available resources?
2. **An individual engagement:** What exactly are we trying to establish, and what work and evidence justify our conclusion?
3. **Management action and follow-up:** Has the response been implemented, what risk remains, and does unresolved exposure require escalation?

Supervision, professional judgment, communication, documentation, confidentiality and independence run through all three. They are not final-stage checks. The IIA explicitly describes engagement work as overlapping and iterative rather than rigidly sequential. [PDF, p. 92]

1. The foundation: what is shared, and what can vary?

The standards are not a universal procedure manual

The document distinguishes three different things:

- **Requirements:** mandatory professional practices within the Standards.
- **Considerations for Implementation:** common or preferred approaches to consider.
- **Examples of Evidence of Conformance:** possible ways to demonstrate that requirements have been implemented, not compulsory templates or an exhaustive list.

This distinction is explicit on page 8. A risk assessment may be required while a particular heat map is not. Supporting documentation may be required while a particular Excel template is not. Findings must be prioritised using the CAE's methodology, but the Standards do not impose one universal red/amber/green scale.

“Mandatory within the professional framework” should also not be confused with “a legal requirement imposed identically in every jurisdiction.” An audit function must understand its applicable laws, regulatory requirements, mandate and organisational policies. The Standards provide the shared professional baseline; they do not eliminate those additional obligations or contextual differences. Relevant Topical Requirements are another part of the IIA framework, but their current subject-by-subject applicability has not been mapped in this consolidation. [PDF, pp. 5-9, 116-119]

Three layers must stay distinct

Professional foundation: independence, objectivity, risk-based planning, appropriate evidence, supported judgments, effective communication, supervision and follow-up.

The audit function's methodology: terminology, rating methods, sampling approaches, document templates, review arrangements, escalation procedures, retention policies and the way work is organised.

The particular engagement: its business objective, risks, applicable criteria, people, systems, locations, evidence, timing and constraints.

Two teams can satisfy the same requirement through different working methods. Conversely, following a familiar template does not establish that the underlying requirement has been met.

Assurance is not the same as advice

In an **assurance engagement**, auditors independently assess an activity against suitable criteria and reach a conclusion about its governance, risk management or controls.

In an **advisory engagement**, the work might help a team think through a new process, facilitate a risk discussion or advise on a proposed system. The nature and scope are agreed with relevant stakeholders. Some requirements expressly allow a different treatment for advice: a formal documented engagement risk assessment, evaluation criteria or evidence gathered to develop findings may not be necessary, depending on that agreement. This does not remove the need for competence, objectivity, appropriate

documentation and effective communication, or permit auditors to assume management responsibility. [PDF, pp. 10, 92, 95, 100, 106]

2. The people, their responsibilities and their decisions

These are roles, not a mandatory staffing chart. A large department may distribute them across many people; a small function may combine several. “Board” can mean an audit committee or another highest-level governing body, not necessarily a corporate board of directors. [PDF, pp. 9-10]

The board or equivalent governing body provides oversight and authority. It approves the audit plan and significant changes, considers resource and independence concerns, and receives significant results and unresolved risk concerns. It is not normally the reviewer of each individual test workpaper. [PDF, pp. 37-38, 42, 46-47, 66-67, 84-85]

The chief audit executive (CAE) is accountable for the audit function's work: its plan, methodologies, resources, quality, significant professional judgments, communications and escalation. Qualified professionals may carry out delegated responsibilities, but accountability remains with the CAE. It would therefore be inaccurate to assume that the CAE must personally perform every review click or every test. [PDF, pp. 90-92]

The engagement supervisor or manager helps turn the engagement's purpose into executable work. They challenge scope, methods, evidence and conclusions, resolve or escalate problems, supervise progress and review the team's work. Supervision can send work back for clarification, more evidence or different procedures. [PDF, pp. 90-91]

The auditor or specialist understands the activity, develops and performs procedures, evaluates information, investigates exceptions, documents reasoning and proposes conclusions. Specialists may contribute technology, data, operational or other expertise. Their contribution still needs to fit the engagement's objective and review arrangements.

Management of the activity under review explains how the activity operates, provides access and evidence, discusses facts and risks, and owns the operational response. Cooperation is important, but management's disagreement does not by itself invalidate a supported audit finding. [PDF, pp. 93, 107-110]

Control owners, action owners and evidence providers may be different people. The person who extracts a database is not necessarily the person accountable for the process. The manager accepting an action may not be the employee implementing a system change. These distinctions affect requests, explanations, accountability and follow-up.

Other assurance providers may already examine related risks. Internal audit coordinates with them and assesses whether reliance is justified. Their work is not automatically usable simply because it is called an audit, assessment or certification. The basis for reliance must be understood and documented, and the CAE remains responsible for the internal audit conclusions. [PDF, Standard 9.5, pp. 69-71]

3. Cycle one: deciding what the organisation needs audited

The question being answered

Where does the organisation most need independent assurance or advice, what coverage is feasible, and what significant exposure will remain less examined?

An audit plan is therefore a choice about coverage and resources, not simply a calendar or a list of departments.

Inputs

The team needs to understand organisational objectives and strategy, how the organisation operates, changes to its systems and activities, management's view of risk, previous audit results, open issues, important incidents, applicable obligations, and other assurance coverage. The board's and senior management's perspectives are required inputs to the documented assessment supporting the plan.

Possible auditable subjects include processes, business units, locations, products, systems, programmes, projects and cross-functional risks. The borders of departments may not match the path of the risk. A payment, for example, can pass through procurement, finance, technology and an external service provider.

What the team actually does

1. Builds or refreshes its understanding of objectives and operations.
2. Identifies significant risks and changes, challenging information where necessary.
3. Looks at existing assurance and whether it is credible and sufficient.
4. Develops possible engagements and estimates the skills, time and other resources needed.
5. Makes coverage trade-offs, including what is deferred or omitted and why.
6. Discusses the proposed plan with the board and senior management and obtains the required approval.
7. Revisits the plan when risks, priorities, resources or access change.

The difficult judgments

- Is management's risk assessment dependable, or does it understate a problem?
- Is a recent incident isolated or a signal of wider exposure?
- Would another audit duplicate credible assurance, or address an actual gap?
- Is a specialist needed, and is that capability available?
- Should an emerging risk displace a planned engagement?
- If a high-risk area is omitted, what is the justification and who needs to understand the consequence?

Outputs and review

The essential outputs are a documented risk basis, an audit plan and its resource requirements, visible limitations and trade-offs, and evidence of discussion and approval. An audit-universe register, heat map, assurance map, capacity spreadsheet or multi-year schedule may help, but none of those named formats is a universal requirement.

The documented organisation-wide assessment must be performed at least annually. The plan must be dynamic and updated in response to change; significant changes require board approval. Resource limitations, omitted high-risk assurance work, conflicting demands and restrictions on scope or access must be communicated. [PDF, Standard 9.4, pp. 66-69]

The feedback loop

An engagement may uncover a risk affecting several business units. Several apparently separate findings may reveal the same underlying weakness. Delayed remediation may change the view of residual risk. These results feed the next coverage decision rather than remaining trapped inside completed engagements. Periodic reporting can therefore include cross-engagement themes and broader conclusions, not only individual reports. [PDF, Standard 11.3, pp. 80-83]

4. Cycle two: planning an individual engagement

4.1 Understand the assignment and the real activity

Question: What are we here to establish, and how does this activity actually achieve its objectives?

The starting point is the reason the engagement exists, not merely its title. “Procurement audit” could refer to tendering, supplier onboarding, contracting, purchasing, receipt of goods or payment. It does not yet identify a workable objective.

Inputs commonly include the plan rationale, stakeholder concerns, previous work, policies, organisational responsibilities, system information, process descriptions, performance information and records of actual activity.

Work can include interviews, observation and tracing a transaction through its actual route. The auditor looks for decisions, handoffs, dependencies, exceptions and the evidence each step leaves. A written procedure may describe the normal route but omit emergency processing, manual overrides, outsourced steps or local workarounds.

Decisions include which risks matter, what changed since the plan was approved, whether fraud risks need attention, what management considers success and where described controls might fail.

Outputs may include an updated engagement risk assessment, a process narrative or flowchart, interview notes and a clearer explanation of the important risks and controls. These are working understandings that may be revised, not facts made permanent by putting them into a template. [PDF, Standards 13.1-13.2, pp. 93-97]

4.2 Establish objectives, scope and criteria

Three different questions must be answered:

- **Objective:** What are we trying to determine?
- **Scope:** What activities, systems, locations and period will the work cover?
- **Criteria:** Against what appropriate expectations will we assess what we find?

For example, “determine whether payment-authorisation controls operated effectively for the defined payment channels during the selected period” is more useful than “review payments.” Its scope must be sufficient to support that objective.

Criteria may come from applicable laws, policies, contracts, targets, established practices or appropriate frameworks. They must be relevant to the objective. Where management's criteria are adequate, auditors must use them; where inadequate, auditors identify appropriate criteria through discussion with the board and/or senior management. Auditors should not select an easier benchmark after seeing the result. [PDF, Standards 13.3-13.4, pp. 98-101]

A justified boundary is different from a scope limitation. Choosing not to cover a lower-risk location can be a reasoned scope decision. Being refused the records necessary to answer the objective can prevent the planned work. Limitations must be discussed with management and, if unresolved, escalated by the CAE to the board through the established methodology.

Objectives and scope, including changes, require CAE approval under the function's appropriate delegation arrangements. Changes also need timely communication to management. Discoveries during fieldwork can legitimately reopen planning. [PDF, pp. 93, 98, 90-92]

4.3 Turn the question into a work programme

Question: What work would provide a reasonable basis for the conclusion we intend to make?

The auditor considers whether to examine control design, operation or both; what population and period are relevant; what evidence would demonstrate the control; which procedures fit the question; and what skills, tools, access and time are required.

The distinctions matter:

- A **risk** is what might prevent the objective from being achieved.
- A **control** is an action intended to manage that risk.
- A **criterion** states the relevant expected condition.
- A **test** is the procedure used to assess the actual condition.
- **Evidence** is the information supporting that assessment.
- A **conclusion** is the auditor's judgment based on the work and evidence.

A walkthrough can establish understanding of a process without proving that its control operated consistently throughout a period. A policy can show the intended requirement

without proving compliance. An automated check across all available rows can still be inadequate if the extract excludes an important payment channel.

Required output: a documented work programme that identifies evaluation criteria, tasks, methods and tools, and the auditors assigned. It must be reviewed and approved before implementation, with changes approved promptly. Resources must be assessed for their appropriateness and sufficiency, with concerns raised to the CAE. [PDF, Standards 13.5-13.6, pp. 101-104]

Variable practice: the work programme may sit in an audit platform, spreadsheet, document or another controlled method. A risk-control matrix is useful for some teams, but the Standards do not require that exact artefact. Nor do they prescribe a single sample size for every test.

5. Fieldwork: producing evidence rather than just completing procedures

5.1 Obtain and assess information

The team requests information from its holders, explains the required period and coverage, resolves ambiguous requests and follows up missing items. Receiving a file is not the same as establishing that it is fit for use.

The auditor asks:

- Does this information address the question and scope?
- Where did it come from, when was it obtained, and which period does it represent?
- Is it current, factual and supported by a dependable source?
- Is the population complete enough for the planned conclusion?
- Do totals, identifiers and definitions reconcile with other reliable records?
- What filters, transformations, assumptions or limitations affect the analysis?
- Is management's explanation corroborated or contradicted elsewhere?

The Standards require information to be relevant, reliable and sufficient. They do not prescribe a universal request tracker or data-validation checklist. The appropriate checks depend on the evidence and the conclusion sought. If evidence is inadequate, auditors must determine what additional information to gather; if relevant evidence cannot be obtained, they must consider whether that itself is a finding. It can also affect the ability to deliver the intended scope and conclusion. [PDF, Standard 14.1, pp. 104-105]

5.2 Perform and document the work

Methods can include interviews, observation, inspection, confirmation, analytical procedures and re-performance. The method must fit the risk and criterion. Different tests may require different combinations.

The working record needs to explain what was examined, what procedure was actually performed, what evidence supported the result, and what judgment followed. It should not simply repeat the planned step with a tick beside it.

For sampling, the basis of selection and limits of inference matter. Selecting high-value or otherwise suspicious transactions can help investigate exposure, but a targeted selection should not be presented as a statistically representative estimate of the whole population. Testing every record in an incomplete extract is not full-population assurance.

The required documentation standard is that an informed, prudent and competent person could repeat the work and derive the same engagement results. Typical workpapers record sources, period, population, selection approach, procedure, results, conclusions, preparer and review evidence. The substance is required; a single prescribed template is not. [PDF, Standard 14.6, pp. 111-112]

5.3 Investigate apparent exceptions

An apparent difference is a **potential finding**, not automatically a final finding.

An approval might genuinely be absent. It might be stored elsewhere, relate to another valid process, fall under an authorised exception, or appear absent because the data join is wrong. The auditor investigates before deciding which explanation is supported.

Typical decisions are to obtain corroboration, clarify criteria, correct an analysis, expand testing, modify the work programme or resolve the apparent exception. If further analysis is required, the work programme must be adjusted and approved. Significant risks cannot simply be dropped to preserve the timetable. [PDF, Standards 14.2-14.3, pp. 106-108]

5.4 Review is part of the investigation

The supervisor tests the reasoning as well as the presentation:

- Does the population support the stated scope?
- Does the procedure address the risk and criterion?
- Does the evidence support the result?
- Have contradictory facts and plausible explanations been considered?
- Is the conclusion stronger than the work justifies?
- Are unresolved limitations visible?

A review note can lead to a corrected calculation, additional testing, a narrower conclusion or a changed finding. Resolving it means addressing the underlying question, not merely marking the comment closed. The Standards require documented supervision; practices for retaining or clearing review notes can vary. [PDF, Standard 12.3, pp. 90-91]

6. From evidence to findings and an overall conclusion

A finding is an evaluated issue

The auditor compares the condition with the criteria, investigates significance, collaborates with management to identify root causes where possible, and considers potential effects. Findings are prioritised using the CAE's established methodology. A significant risk must be documented and communicated as a finding; treatment of other risks depends on circumstances and methodology. [PDF, Standard 14.3, pp. 107-108]

Useful questions include:

- What exactly happened, and what evidence supports that statement?
- Which criterion was not met?
- Is the issue isolated, repeated, systemic or still uncertain?
- What caused it, and how strong is our basis for that explanation?
- What has actually occurred, as distinct from what could occur?
- What controls remain, and how do they affect residual risk?
- How significant is this issue in its business context?

For example, an unauthorised transaction route creates exposure, but it does not by itself prove fraud or financial loss. A calculated amount of transactions exposed to a weakness is not automatically a loss amount. An uncertain root cause should not be presented as established fact.

Management discussion improves accuracy without transferring the judgment

Management may provide missing evidence, explain an exception, challenge the interpretation or identify a more effective response. Auditors should revise conclusions when that information provides a valid reason.

But a preference for a lower rating is not evidence. If disagreement remains, the established methodology must allow both positions and their rationale to be expressed. Auditors are not required to change a supported result simply to obtain agreement. [PDF, Standard 13.1, p. 93; Standard 14.4, p. 109]

Recommendations and management actions are related but different

Auditors may develop recommendations, request management action plans or work collaboratively on appropriate actions. The response should address the difference, relevant risk and root cause rather than only the symptom.

Management owns implementation. It determines how to operate the process, deploy resources and execute the response. Audit can challenge whether a proposed action is adequate without becoming the process owner. One finding may need several actions; one systemic action may address several findings. Those relationships should not be confused with the finding's original evidence or significance. [PDF, Standard 14.4, pp. 109-110]

An engagement conclusion is more than a list of findings

The auditor assesses the combined significance of the results relative to the engagement and management objectives. A conclusion cannot safely be obtained by mechanically counting findings or averaging colours.

For assurance work, the conclusion must express judgment about the relevant governance, risk management or control effectiveness, including recognition where processes are effective. An engagement with no reportable findings still needs a supported conclusion; it is not proof that all risk has been eliminated. [PDF, Standard 14.5, pp. 110-111]

7. Reporting and completing the engagement

The purpose of the final communication

The recipient should understand what was examined, what was established, what its significance is, what limitations apply and what needs to happen next.

For every engagement, the final communication includes objectives, scope, conclusions and recommendations and/or action plans where applicable. Assurance communications also include findings and their significance and priority, scope limitations where present, and the effectiveness conclusion. Responsible individuals and planned action dates must be specified. Actions already initiated or completed before communication must be acknowledged. [PDF, Standard 15.1, p. 113]

Review and approval

The work and communication need to be supported, accurate, objective, clear, concise, constructive, complete and timely. The final communication requires CAE review and approval before issue, with the delegation and accountability principles described above. An unsupported claim of conformance is not justified merely because the team used the usual template. Where engagement nonconformance applies, the required disclosure covers the affected standard, reason and impact. [PDF, pp. 90-92, 113-114]

The final communication need not be a single standardised Word report. Formats, depth and audiences can differ; oral communication may be supported by slides or written records. A board summary and a detailed management report serve different needs. [PDF, p. 114]

Completion does not erase later obligations

The team retains the engagement record according to applicable requirements and its policies. If a significant error or omission is later identified, corrected information must promptly reach all recipients of the original communication. [PDF, Standards 14.6 and 11.4, pp. 111, 83]

Issuing the report completes an important communication obligation. It does not mean management's corrective work is finished or that internal audit has confirmed implementation.

8. Cycle three: management action, follow-up and risk acceptance

Three different claims

1. Management has proposed or committed to an action.
2. Management reports that it has completed the action.
3. Internal audit has performed the appropriate follow-up and confirmed implementation.

These claims require different evidence and should not be collapsed into one “done” status.

What follow-up involves

The auditor obtains progress information, examines relevant implementation evidence, performs risk-based follow-up assessments and updates the action's status in a tracking system. The depth of procedures depends on the finding's significance. A low-risk procedural change and a major system control failure do not necessarily need the same follow-up work. [PDF, Standard 15.2, pp. 114-115]

A new policy may show that a document was issued. It may not establish that staff follow it. A configuration screenshot may demonstrate a setting at a point in time, but not necessarily sustained operation. Where effectiveness is the relevant question, the methodology should determine the further evidence or testing needed.

The tracking system may be a spreadsheet, database or application. The required substance is confirmation through the established methodology, risk-based assessment and an updated status, not a particular software tool or universal closure workflow.

When plans change or become overdue

If implementation does not progress according to the agreed dates, auditors must obtain and document management's explanation and discuss it with the CAE. An alternative action may be appropriate if it addresses the issue satisfactorily; the alternative should then be tracked through completion. [PDF, p. 115]

An overdue action is not automatically proof of unacceptable risk acceptance. The CAE must evaluate the actual exposure, management's response and the organisation's appetite or tolerance. If accepted risk exceeds that level, the matter must be discussed with senior management and, if unresolved, escalated to the board. Resolving the risk remains management's responsibility, not the CAE's. [PDF, Standard 11.5, pp. 84-85]

Feedback into future assurance

Repeated delays, ineffective fixes, recurring findings and weaknesses spanning several engagements may justify broader reporting or a different future audit priority. Follow-up is therefore both an accountability process and an important source of information about how the organisation manages risk.

9. One worked example from selection to follow-up

The following is a **hypothetical payment-control engagement**, not a real case or a prescribed sampling method. Its purpose is to show how the work moves between people, evidence and decisions.

1. Why the engagement exists. A changed payment process and recent near misses lead the CAE to propose assurance over payment authorisation. The coverage decision considers other risks and available capacity. The engagement is included in the approved plan.

2. Understand the process. The auditor reads the payment policy, interviews finance and technology staff and traces transactions. The walkthrough reveals a manual emergency route outside the normal workflow. The team's initial understanding changes.

3. Define the engagement. The objective is to evaluate whether defined authorisation controls operated over the chosen period. Scope includes normal and emergency routes. The applicable policy and approved exceptions provide criteria. The work programme specifies how records and approval evidence will be examined and receives approval.

4. Challenge the data. The first extract contains 1,212 payments, but a reconciliation identifies 1,240 completed payments. The missing 28 are manual payments. The auditor obtains the additional records before treating the population as complete. A full analysis of the first file alone would have missed the very route that required attention.

5. Investigate exceptions. A targeted selection of 40 distinct higher-risk payments produces seven apparent missing approvals. Further work finds valid approvals stored elsewhere for three and an applicable authorised exception for one. Three remain confirmed exceptions. The auditor does not describe all seven as control failures or extrapolate three out of 40 to the entire population.

6. Extend the work. Because the confirmed exceptions involve the manual route, the team revises and obtains approval for the additional work, then examines all 28 manual payments. Six confirmed exceptions are identified in that group, including the original three. The wording and denominators now distinguish the targeted selection from the complete manual-payment group.

7. Develop and review the finding. Evidence supports a weakness in the manual approval route. The auditor and management investigate why it occurred. The supervisor challenges whether the evidence supports the proposed cause, rating and effect. The finding describes the unauthorised-payment exposure without claiming an actual loss that has not been established.

8. Agree a response. Management proposes a preventive change to the manual route and an independent review of remaining exceptions. Owners and target dates are specified. The auditor assesses whether these actions address the issue and documents any unresolved difference.

9. Communicate. The approved final communication states the objective, scope, work-supported results, finding significance, overall conclusion and management actions. If

management has already made part of the change, that progress is acknowledged without rewriting what happened during the audited period.

10. Follow up. Management later reports completion. Audit confirms that the workflow change has been implemented, but finds that the independent review has not yet operated. The two actions therefore have different statuses; the finding is not treated as fully addressed merely because one action is complete. Later risk-based follow-up establishes whether the remaining action has been implemented and supports the appropriate final status. If delay leaves unacceptable risk unresolved, the escalation process applies.

The important lesson is not the numbers. The work changed when the process, data, exceptions and review revealed something new. The quality of the conclusion depended on preserving those distinctions.

10. What differs across industries and teams?

The same professional questions can involve very different evidence, criteria and operational constraints. These are illustrative contrasts, not claims that every team in an industry works in the same way.

Banking or financial services: an engagement might examine lending decisions, payments, customer treatment or regulatory reporting. Relevant evidence could include transaction histories, approval authorities, system records and regulatory submissions. The applicable jurisdiction and regulatory scope can add specific obligations. Those obligations must be researched for the actual organisation rather than assumed from the industry label.

Manufacturing: an engagement might concern inventory, production continuity, procurement or capital expenditure. Physical observation, counts, maintenance records and tracing movement through locations may matter alongside system data. A process can operate differently across plants or shifts, making one central policy insufficient evidence of consistent operation.

Telecommunications or digital services: questions might concern access, provisioning, billing, channels or third parties. Event sequences, identifier definitions, system dependencies and data timing can materially affect conclusions. Large data volumes do not remove the need to establish what the records represent.

Healthcare or other sensitive-service settings: evidence may involve restricted access, service-quality objectives and specialised operational knowledge. Clinical or technical expertise may be needed for certain objectives. A general auditor should not replace relevant specialist judgment with a generic controls checklist.

Public sector: the Standards themselves explain variations in legal mandates, governance, budget authority, public reporting, external assurance arrangements and stakeholder accountability. An audit committee may not hold the same powers as a corporate board. Public disclosure can affect what is communicated and retained. These are substantive differences, not cosmetic terminology changes. [PDF, pp. 116-119]

Small versus large audit functions: the same person may prepare, lead and manage much of an engagement in a small function, creating different supervision and quality arrangements. The Standards note that a one-person function needs outside assistance for

an adequate quality assurance and improvement programme. Larger functions may have multiple specialists and review levels, but extra layers do not automatically improve judgment. [PDF, pp. 9, 90-92]

Centralised, distributed and outsourced delivery: locations, language, systems and service-provider involvement can alter handoffs and available evidence. Outsourcing work does not transfer the CAE's ultimate accountability for its quality. [PDF, pp. 7-8, 90-92]

Industry is only one source of variation. Mandate, organisational complexity, risk maturity, staffing, data quality, engagement type and jurisdiction can matter as much or more.

Published examples that corroborate variation

The Basel Committee's guidance on internal audit in banks provides a concrete financial-services example. Its paragraphs 32-44 discuss specialised subjects and evidence such as risk information, capital and liquidity processes, stress testing and valuation. It also addresses relationships with banking supervisors. This is supervisory guidance, applied in context, not a universal bank work programme or a substitute for national requirements.

Penn's published audit process provides a concrete institutional example covering the University and Penn Medicine. It describes planning, fieldwork, ongoing discussion, reporting and follow-up; project timing considers matters such as grant deadlines and accreditation reviews. Its follow-up practice includes updates on open observations three times a year, with interviews, tests or revised procedures used according to severity to substantiate implementation. That cadence and reporting arrangement illustrate Penn's method, not an IIA-wide obligation or the practice of every university or healthcare organisation.

These examples reinforce the distinction: the standard of professional work remains shared, while subjects, criteria, evidence sources, review arrangements, audiences and follow-up timing can differ. They add published institutional and supervisory corroboration; they do not replace direct practitioner validation.

11. The exceptions that reveal how auditing really works

The smooth sequence conceals much of the actual effort. These situations expose important decisions:

- **Records arrive late or incomplete:** clarify the request, test what is missing, assess alternative evidence and decide whether the objective remains achievable.
- **The policy differs from actual practice:** investigate whether the practice is an authorised variation, a weakness or a sign that the criteria themselves need examination.
- **Evidence contradicts an interview:** pursue the contradiction rather than favouring the more senior speaker.
- **A test finds an unexpected risk:** reconsider the risk assessment, scope and work programme; obtain the relevant approvals and communicate changes.

- **Management supplies evidence after a draft finding:** assess it and revise where warranted; do not preserve an unsupported finding merely because it was already drafted.
- **The reviewer rejects the logic:** revise the work or conclusion, not only the wording.
- **Management corrects the problem before reporting:** acknowledge the action while accurately reporting the reviewed-period condition and remaining risk.
- **The action owner changes or proposes a different fix:** preserve accountability and evaluate the revised response rather than treating it as automatic closure.
- **A significant error is found after reporting:** correct recipients' understanding promptly.
- **An auditor has a relevant conflict or prior operational responsibility:** disclose and manage the impairment; changing the document template cannot solve an objectivity problem. [PDF, Standards 2.2-2.3, pp. 22-24]

These are not unusual side cases to exclude from the operating model. They are how professional judgment, supervision and communication become visible.

12. What this consolidation establishes, and what still needs validation

We now have a standards-based account of the decisions and responsibilities spanning organisational coverage, an individual engagement and management follow-up. It explains why the audit cannot be reduced to a checklist, a report-writing exercise or a fixed sequence of status changes.

What it does **not** establish is how frequently particular problems occur, how much time different roles spend on them, which artefacts teams genuinely rely on, or where current tools fail in daily use. Those questions need observation and real examples across more than one type of team.

The next research should examine sanitised engagement packs and walk through actual decisions with preparers, reviewers and action owners. Useful examples include a straightforward engagement, one with disputed findings, one with substantial data problems, one that changed scope and one with delayed or ineffective remediation. The aim is to test this map, not to ask people to confirm a product design already chosen.

For each example, we should establish: what triggered the work; what information was available; what the person actually did; where judgment was required; who reviewed or approved it; what changed; what evidence supported the decision; and what happened next.

That is the boundary between understanding the shared professional work and prematurely imposing one organisation's working style on every internal audit team.

Source guide

Primary source: **The Institute of Internal Auditors, Global Internal Audit Standards, published 9 January 2024**, the PDF supplied in this conversation. The paragraphs above paraphrase the source rather than reproducing it.

- Framework, applicability, requirement/guidance distinction and small functions: pp. 5-10.
- Objectivity and impairments: Standards 2.2-2.3, pp. 22-24.
- Governance and role distinctions: pp. 37-38; Standard 6.2, pp. 42-43; Standard 7.1, pp. 46-49.
- Organisational risk assessment and audit planning: Standard 9.4, pp. 66-69.
- Coordination and reliance: Standard 9.5, pp. 69-71.
- Periodic results, broader conclusions and correction: Standards 11.3-11.4, pp. 80-83.
- Unacceptable risk acceptance and escalation: Standard 11.5, pp. 84-85.
- Supervision, delegation and iteration: Standard 12.3 and Domain V introduction, pp. 90-92.
- Engagement communication, understanding, risk, objectives, criteria, resources and work programme: Standards 13.1-13.6, pp. 93-104.
- Evidence, analyses and finding evaluation: Standards 14.1-14.3, pp. 104-108.
- Recommendations, conclusions and documentation: Standards 14.4-14.6, pp. 109-112.
- Final communication and follow-up: Standards 15.1-15.2, pp. 113-115.
- Public-sector application: pp. 116-119.

Additional primary sources:

- IIA public edition of the supplied 2024 Standards.
- Basel Committee, The internal audit function in banks, June 2012, particularly paragraphs 32-44 and Principle 16. Used for sector-specific examples, not jurisdiction-specific legal advice.
- University of Pennsylvania Office of Audit, Compliance and Privacy, Audit Process. Used as one institution's published implementation, not an industry-wide prescription.

Source links for print readers

IIA Standards
https://www.theiia.org/globalassets/site/standards/globalinternalauditstandards_2024january9.pdf

Basel Committee
https://www.bis.org/publications/201206-guidelines-internal-audit-function-banks.pdf

University of Pennsylvania
https://oacp.upenn.edu/audit/audit101/audit-process/